

# Security+ 4.6 · Password Security

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.6 — Password Security (6:22)** · [Vídeo no YouTube ↗](#)

---

**Resumo da Aula:** Password: COMPRIMENTO > complexidade (14+ é melhor); password manager (gera forte, guarda cifrado); passwordless (FIDO2/YubiKey, biometria, Magic link) = o futuro; NIST: sem troca forçada (incentiva fraca).

## Highlights que a prova cobra

---

- Comprimento > complexidade (14 chars simples > 8 complexos)
- FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing

## Dicas de prova & Cenários Típicos

---

- 'length over complexity'=NIST 800-63B guidance

**Cenário clássico de exame:** 'senha de 16 chars simples é melhor que 10 chars complexos'=NIST guidance.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

## Armadilhas da Seção 4.6)

**Por que este aprofundamento é cobrado no exame?** O vídeo do Professor Messer (Password Security) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Monitoramento de Segurança (SIEM, SOAR, EDR/XDR):**
  - **SIEM:** centraliza, normaliza e correlaciona eventos de logs em tempo real para disparar alertas de segurança.
  - **SOAR:** automatiza respostas a incidentes através de playbooks coordenados, reduzindo o tempo de reação humano.
  - **EDR/XDR:** detecção e resposta a anomalias no endpoint (EDR) estendida a e-mail, nuvem e identidades (XDR).
- **Fases da Resposta a Incidentes (NIST SP 800-61 / PICERL):**
  1. **Preparação:** políticas, ferramentas, treinamentos.
  2. **Identificação/Detecção:** triagem de alertas e confirmação do incidente.
  3. **Contenção:** isolamento do sistema afetado para impedir propagação (sem destruir provas).
  4. **Erradicação:** remoção de malwares, fechamento de brechas e contas comprometidas.
  5. **Recuperação:** restauração segura dos serviços a partir de backups limpos e validação de produção.
  6. **Lições Aprendidas:** reunião pós-incidente e melhorias nos playbooks.
- **Forense Digital e Ordem de Volatilidade (RFC 3227):** Durante a coleta de evidências forenses, os artefatos mais voláteis (que somem ao desligar) devem ser capturados primeiro:
  1. Registradores da CPU e memória Cache.
  2. Memória RAM (volátil: contém senhas em claro, chaves criptográficas em uso e conexões ativas).
  3. Estado das conexões de rede e processos em execução.
  4. Sistema de arquivos e discos rígidos (HD/SSD).
  5. Mídias ópticas e backups externos arquivados.

### ⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- NUNCA desligue ou reinicie um servidor comprometido antes de realizar o dump forense da memória RAM; reiniciar destrói evidências essenciais de malwares fileless.
- Qualquer manipulação de evidência digital exige cálculo imediato de hash (SHA-256) e registro rigoroso da Cadeia de Custódia (Chain of Custody).

## ✓ Perguntas de treino comentadas (10 questões)

---

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

**1. MFA combina fatores de categorias diferentes. Qual trio representa as 3 categorias?**

- A)** Senha, PIN e resposta secreta
- B)** Algo que sabe, algo que tem, algo que é
- C)** 3 senhas diferentes
- D)** Usuário, senha e e-mail

**2. MFA exige pelo menos dois fatores de autenticação. Qual combinação representa autenticação de múltiplos fatores genuína?**

- A)** Senha + PIN
- B)** Senha + Token físico
- C)** Dois tipos de biometria
- D)** Pergunta de segurança + Senha

**3. A forma correta de ARMAZENAR senhas de usuários:**

- A)** Hash com salt (ex: bcrypt)
- B)** Criptografia AES reversível
- C)** Texto claro protegido por firewall
- D)** Base64

**4. Cenário corporativo (Password Security):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'Comprimento > complexidade (14 chars simples > 8 complexos)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**5. Cenário corporativo (Password Security):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**6. Cenário corporativo (Password Security):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'length over complexity'=NIST 800-63B guidance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guidance...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**7. Cenário corporativo (Password Security):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'senha de 16 chars simples é melhor que 10 chars complexos'=NIST guidance.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'senha de 16 chars simples é melhor que 10 chars complexos'=NIST guidance....

**8. Cenário corporativo (Password Security):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'Comprimento > complexidade (14 chars simples > 8 complexos)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**9. Cenário corporativo (Password Security):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: 'FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**10. Cenário corporativo (Password Security):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.6), um analista avalia o seguinte requisito técnico: '"length over complexity'=NIST 800-63B guidance'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guidance...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

## GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

### 1) B — Algo que sabe, algo que tem, algo que é.

✓ **Por que está certa:** MFA de verdade mistura categorias: conhecimento (senha), posse (token/celular) e inerência (biometria). Três senhas são o MESMO fator — não é MFA.

#### ✗ **Por que as outras estão erradas:**

- *Senha, PIN e resposta secreta:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *3 senhas diferentes:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Usuário, senha e e-mail:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 2) B — Senha + Token físico.

✓ **Por que está certa:** MFA verdadeira combina fatores de categorias diferentes: algo que você sabe (senha) + algo que você tem (token físico). Múltiplos fatores da mesma categoria não constituem MFA.

#### ✗ **Por que as outras estão erradas:**

- *Senha + PIN:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Dois tipos de biometria:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Pergunta de segurança + Senha:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 3) A — Hash com salt (ex: bcrypt).

✓ **Por que está certa:** Senha se guarda como HASH salgado (bcrypt/argon2) — não reversível. Nunca em texto claro nem cripto reversível (a chave vaza junto).

#### ✗ **Por que as outras estão erradas:**

- *Criptografia AES reversível:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Texto claro protegido por firewall:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Base64:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 4) A — Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): Comprimento > complexidade (14 chars simples > 8 complexos).

#### ✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**5) A — Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**6) B — Implementar a solução correspondente: 'length over complexity' = NIST 800-63B guidance....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): 'length over complexity' = NIST 800-63B guidance.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**7) D — Implementar a solução correspondente: 'senha de 16 chars simples é melhor que 10 chars complexos' = NIST guidance.....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): 'senha de 16 chars simples é melhor que 10 chars complexos' = NIST guidance..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**8) A — Implementar a solução correspondente: Comprimento > complexidade (14 chars simples > 8 complexos)....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): Comprimento > complexidade (14 chars simples > 8 complexos).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**9) C — Implementar a solução correspondente: FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**10) B — Implementar a solução correspondente: 'length over complexity'=NIST 800-63B guidance....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.6 (Password Security): 'length over complexity'=NIST 800-63B guidance.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.